Living off the land: tool analysis

certutil.exe

What it is	Built-in Windows certificate utility
How it's abused	Downloads files through its URL cache function
ATT&CK	T1105 Ingress Tool Transfer
Where I'd look	Windows Security Event ID 4688 with command line logging

I chose **certutil.exe**, a Windows utility that administrators use to inspect and verify digital certificates and troubleshoot certificate services. It serves a legitimate purpose, so blocking it completely could interfere with administrative work.

How an attacker misuses it

An attacker could misuse certutil to download a malicious file from an external website onto a compromised computer. The LOLBAS Certutil entry documents how its URL cache functionality can download and save files. This stood out to me because the attacker is using a tool already available in Windows to bring in malware. The download itself does not execute the file, but it can prepare the next step of an attack.

How I would detect it

To detect misuse, I would monitor Windows Security **Event ID 4688** for certutil.exe process creation. I would enable **Audit Process Creation** and the **Include command line in process creation events** setting so I could see the arguments used. Otherwise, the command line field is empty by default. This event also provides the account and, on current Windows versions, the parent process name.

My detection rule would work in two tiers:

Flag it	certutil commands containing the URL cache argument, an HTTP or HTTPS address, and an output filename ending in **.exe**
Raise priority	The file is saved in a user's temporary folder, or the process chain traces back to Word or Excel

Those details would make me question why a certificate utility was downloading an executable during ordinary document use.

Before I call it malicious

I would still investigate before calling it malicious because an administrator could legitimately download a file. I would compare the destination website, user account, and parent process with normal activity, then check whether the downloaded file was executed afterward.

> For me, the key is watching how the tool is used instead of assuming that a familiar Windows program is automatically safe.

Reference: LOLBAS Project, Certutil.exe entry